



Universiteit
Leiden
The Netherlands

Introduction to Information Security

Lecture Handout

Eleftheria Makri

2025-2026

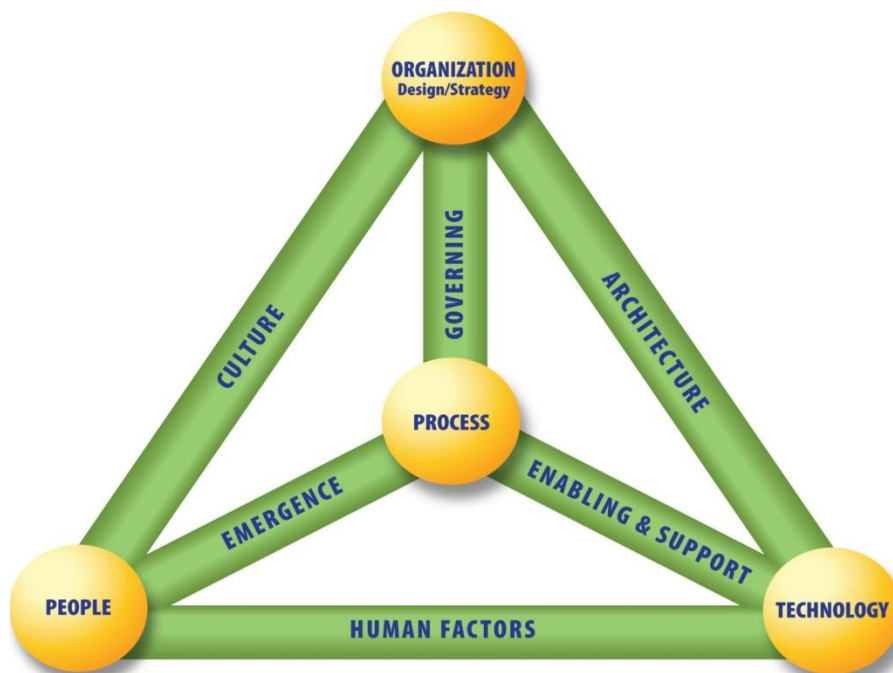
1. Basic Security Definitions

- **Basic Security Principles – The CIA triad:**
 - **Confidentiality:** Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.
 - **Integrity:** Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.
 - **Availability:** Ensuring timely and reliable access to and use of information.

- **Additional Security Goals:**
 - **Authenticity:** The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or message originator.
 - **Authentication:** Verifying the identity of a user, process, or device, often as a prerequisite to allowing access to resources in an information system.
 - **Authorization:** Only approved entities can access the system resources.
 - **Accuracy:** Suitability of information for the purpose.
 - **Accountability:** The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity. This supports non-repudiation, deterrence, fault isolation, intrusion detection and prevention, and after-action recovery and legal action.
 - **Non-repudiation:** Assurance that the sender of information is provided with proof of delivery and the recipient is provided with proof of the sender's identity, so neither can later deny having processed the information.
 - **Privacy:** Restricting access to subscriber or Relying Party information in accordance with federal law and agency policy.

- **Security Definitions:**
 - **Computer Security (COMPUSEC):** Measures and controls that ensure confidentiality, integrity, and availability of information system assets including hardware, software, firmware, and information being processed, stored, and communicated.
 - **Information Systems Security (INFOSEC or IT Security):** Protection of information systems against unauthorized access to or modification of information, whether in storage, processing, or transit, and against the denial of service to authorized users, including those measures necessary to detect, document, and counter such threats.

- **Information Security (1):** The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability.
- **Information Security (2):** Protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide:
 - 1) integrity, which means guarding against improper information modification or destruction, and includes ensuring information nonrepudiation and authenticity;
 - 2) confidentiality, which means preserving authorized restrictions on access and disclosure, including means for protecting personal privacy and proprietary information; and
 - 3) availability, which means ensuring timely and reliable access to and use of information.
- *Information Security* is a broader term including (other than technology) people, processes and organization. ISO 27001 contains 133 Information Security controls in its Annex A, which can be classified as follows:
 - IT related controls : 46%
 - controls related to organization/documentation: 30%
 - physical security controls: 9%
 - legal protection: 6%
 - controls related to relationship with suppliers and buyers: 5%
 - human resources management controls: 4%



- **Asset:** A major application, general support system, high impact program, physical plant, mission critical system, personnel, equipment, or a logically related group of systems.
- **Vulnerability (1):** Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.
- **Vulnerability (2):** A weakness in a system, application, or network that is subject to exploitation or misuse.
- **Threat (1):** Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, individuals, other organizations, or the Nation through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.
- **Threat (2):** The potential source of an adverse event.
- **Threat (3):** Any circumstance or event with the potential to adversely impact organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals through an information system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service. Also, the potential for a threat-source to successfully exploit a particular information system.
- **Risk:** The level of impact on organizational operations (including mission, functions, image, or reputation), organizational assets, or individuals resulting from the operation of an information system given the potential impact of a threat and the likelihood of that threat occurring.

*An **asset** has a **vulnerability**; a **threat** can exploit this vulnerability; exploitation of a vulnerability has an **impact**. Assets, vulnerabilities, threats, and impacts are used to calculate the **risk**. Then **countermeasures** are deployed to reduce the risk.*

- **Security and Risk Management Relationships:** Security management ensures the interrelationships among assessing risk, implementing policies and controls in response to the risks, promoting awareness of the expectations, monitoring the effectiveness of the controls, and using this knowledge as input to the next risk assessment.

3. Trust

Trust is a very important concept in security:

- A **trusted component** is a component/system that has some properties we rely on
 - It might not be possible to verify that a component/system is **trustworthy** (worthy of trust)
 - But we still want to minimize any possibility of compromise for trusted components
 - We trust more if we can verify
- Secure systems design typically requires a (set of) trusted component(s) that is called a **trusted computing base**
 - We want to minimize this trusted computing base
 - This minimization principle applies to
 - not trusting anything, if possible, and
 - designing systems that require minimal trust assumptions

Additional Reading/Source(s)

Glossary of Key Information Security Terms, by NIST.